AI Policy and Regulations

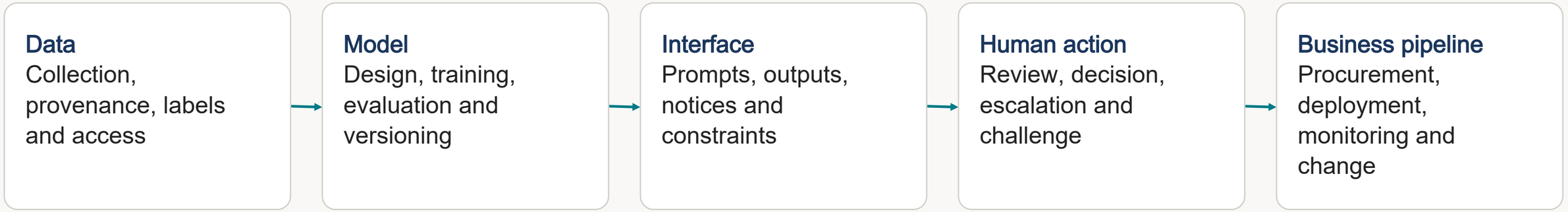
Policy, governance and engineering evidence for AI systems

Sirui Han · The Hong Kong University of Science and Technology
23 October 2026

Source frame: primary sources current to 23 Oct 2026

AI products are governed as systems

A product claim or harm can emerge from the combined socio-technical pathway.



Governing unit · intended use + context + actors + evidence across the pathway

Policy duties rarely attach to the model alone.

Conceptual system schematic · basis: NIST AI RMF 1.0 and OECD AI Principles

Source: NIST AI RMF 1.0 · voluntary risk - management guidance

The policy-to-engineering perspective

Policy language becomes operational through five linked dimensions.

Instrument
Source of authority
Binding duty, recommended practice or auditable criterion

→

Scope
Boundary of application
Purpose, sector, jurisdiction and lifecycle

→

Actor
Holder of duty
Provider, deployer, vendor and user responsibilities

→

Evidence
Demonstration
Documentation, test records, logs and notices

→

Remedy
Response to failure
Challenge, correction, suspension or enforcement

Engineering work makes the applicable policy claim inspectable.

Conceptual policy-to-engineering lens · basis: EU AI Act, OECD AI Principles and NIST AI RMF 1.0

Sources: EU AI Act, consolidated 27 Jul 2026 · NIST AI RMF 1.0

Law, guidance, standards and tests

Enforceability depends on the instrument, the applicable regime and the underlying facts.

Law	Regulatory guidance	Voluntary standard	Test or assurance
Status Binding when in scope	**Status** Interpretive or recommended	**Status** Adopted by choice, contract or procurement	**Status** Evidence about a defined claim
Contribution Creates duties, rights and remedies	**Contribution** Signals supervisory expectations	**Contribution** Structures an organisational system	**Contribution** Measures a method or outcome
Engineering trace Scope record, documentation, controls	**Engineering trace** Rationale, practice and review trail	**Engineering trace** Management process and audit scope	**Engineering trace** Protocol, result, limits and owner

A test pass or standard certificate does not itself establish legal compliance.

Sources: EU AI Act · NIST AI RMF 1.0 · ISO/IEC 42001:2023

The policy problem behind AI deployment

Legitimate deployment holds several public-interest aims together rather than optimizing one metric.

Rights
Dignity, privacy, equality and meaningful agency

Safety
Foreseeable harms receive proportionate prevention and response

Asymmetry
Information and power imbalances remain visible and challengeable

Accountability
Clear responsibility, evidence and routes to remedy

Innovation
Proportionate requirements preserve useful experimentation and learning

Deployment legitimacy depends on the whole set.

Conceptual policy lens · rights are not reducible to accuracy alone

Source: OECD AI Principles, updated 2024

A toolkit for governing AI markets

Market rules alter incentives through complementary mechanisms.

Prohibitions and conditions
Some uses are prohibited or conditioned.

Allocation of duties
Responsibilities follow actor role and context.

Transparency and notices
Relevant people receive usable information.

Risk management and records
Controls generate a traceable basis for decisions.

Testing and assurance
Defined claims receive proportionate scrutiny.

Monitoring and remedy
Incidents, complaints and enforcement close the loop.

Conceptual regulatory toolkit · mechanisms combine differently across legal regimes

Source: EU AI Act, consolidated 27 Jul 2026

A shared vocabulary for responsible AI

International recommendations establish common terms; enforceability still comes from applicable law or contract.

OECD AI Principles · updated 2024

Inclusive growth, sustainable development and well-being
Human-centred values and fairness
Transparency and explainability
Robustness, security and safety
Accountability

UNESCO Recommendation · 2021

A human-rights-centred policy approach. Paraphrased orientations include proportionality, human oversight, privacy, fairness, auditability and sustainability.

Recommendations are not directly binding company law.

The vocabulary guides design choices; applicable legal duties determine compliance.

Sources: OECD AI Principles, 2024 · UNESCO Recommendation, 2021

NIST AI RMF connects governance to risk



Original NIST AI RMF Core functions figure · NIST, 2023

Voluntary AI RMF 1.0 · revision underway, not already replaced

Govern · culture, roles and policy across every function

Map · context, intended use and affected people

Measure · analyze, assess and track relevant risk

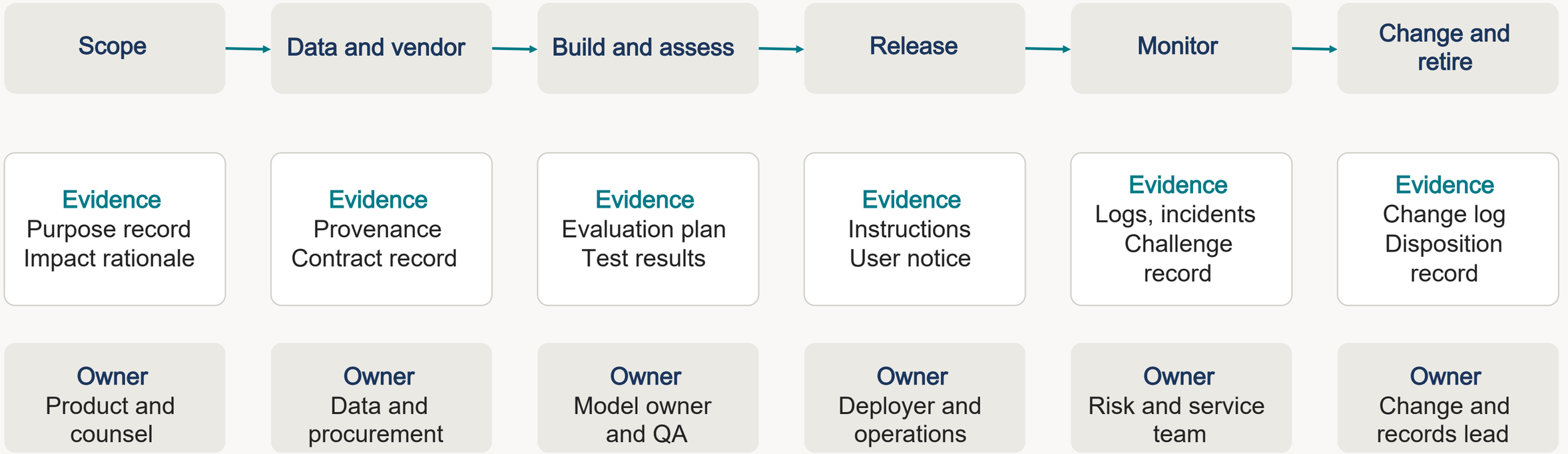
Manage · prioritize, respond and learn from risk

Interpretation: Govern is cross-cutting, not the first box in a linear approval sequence.

Source: NIST AI RMF 1.0 Core functions · original NIST figure, 2023

Evidence across the AI lifecycle

Each lifecycle decision needs an artefact that can be traced to an accountable owner.



Conceptual evidence-and-owner flow · duties and artefacts vary with the applicable regime and system context

Sources: NIST AI RMF 1.0 · EU AI Act, consolidated 27 Jul 2026

Scope and actor roles determine duties

Duty allocation follows applicable definitions, market facts, intended purpose and actual conduct.

Scope filters

Market and jurisdiction
Place, sector and applicable instrument

Intended purpose and use
Function, impact and affected people

Lifecycle and distribution
Configuration, supply chain and deployment

Actor roles

Provider
Develops or places a system under its name. Technical documentation commonly matters.

Deployer
Uses a system within its operations. Instructions, oversight and monitoring matter.

Vendor
Supplies a component, service or capability. Contracts may allocate evidence and support.

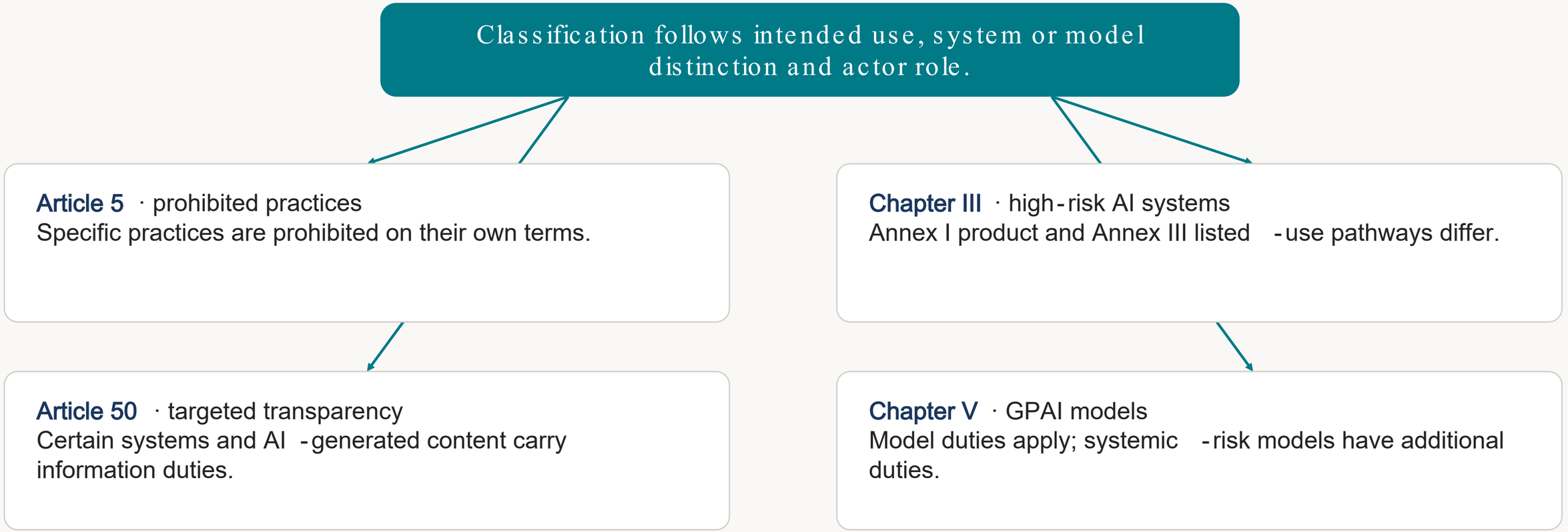
One organisation can occupy multiple roles; labels are not universal legal definitions.

Conceptual role map · applicable legal definitions and contracts control the analysis

Source: EU AI Act, consolidated 27 Jul 2026 · roles are regime-specific

The EU AI Act has overlapping legal layers

Four legal pathways can overlap; they are not a tiered risk pyramid.



Conceptual legal map · provisions apply on their own terms and can combine for one deployment

Source: EU AI Act, consolidated 27 Jul 2026 · legal source frame current to 23 Oct 2026

Prohibited practices set hard boundaries

Article 5 turns on defined conditions. It does not create a blanket ban on biometrics.

Manipulative or exploitative techniques

Materially distort behaviour and cause, or are likely to cause, significant harm.

Social scoring

Detrimental treatment rests on a score and is unrelated to context, or unjustified or disproportionate.

Facial-image scraping

Untargeted scraping of facial images from the internet or CCTV to create or expand databases.

Specific biometric uses

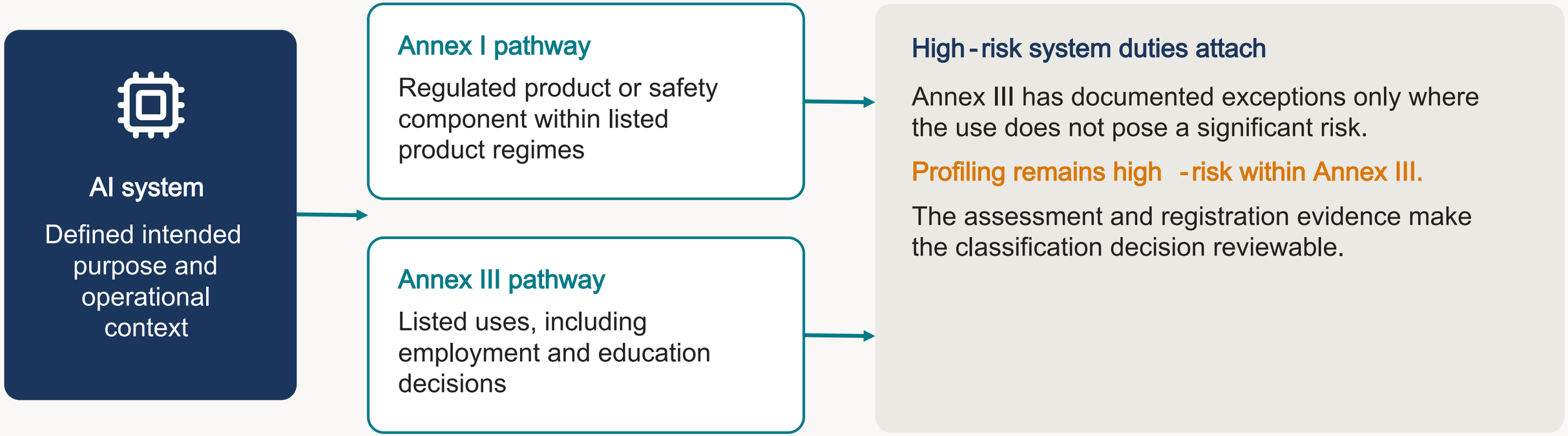
Workplace or education emotion recognition has narrow medical or safety exceptions. Public-space law-enforcement real-time RBI remains conditioned by necessity, authorisation and safeguards.

Engineering boundary: document the intended practice, affected people, harm pathway and any statutory condition or exception before treating a use as prohibited or permitted.

Source: Article 5, consolidated AI Act • current text 27 Jul 2026

High-risk classification follows intended use

Start with the system's intended purpose, then test the relevant legal pathway.



Product pathway and listed-use pathway are distinct routes to the same high-risk operating discipline.

Source: AI Act Annexes I and III • consolidated text 27 Jul 2026

High-risk duties become engineering evidence

Legal duties become reviewable artifacts when the role allocation is explicit.

Duty area	Provider	Deployer	Evidence and accountable owner
Risk and quality	Risk management and quality system	Context monitoring and escalation	Risk file; QMS record Product governance lead
Data and testing	Data governance and validation	Relevant input data under its control	Dataset spec; test results Data and model lead
Human oversight	Oversight measures and instructions	Competent, authorised human oversight	Role card; training; escalation Operations lead
Logs and incidents	Technical documentation and logs	Monitoring, suspension and reporting	Technical file; incident record Compliance owner

One organisation can occupy more than one role; the evidence trail must follow the actual role and intended use.

Source: AI Act Articles 9 –17 and 26 • consolidated text 27 Jul 2026

GPAI models create supply-chain duties

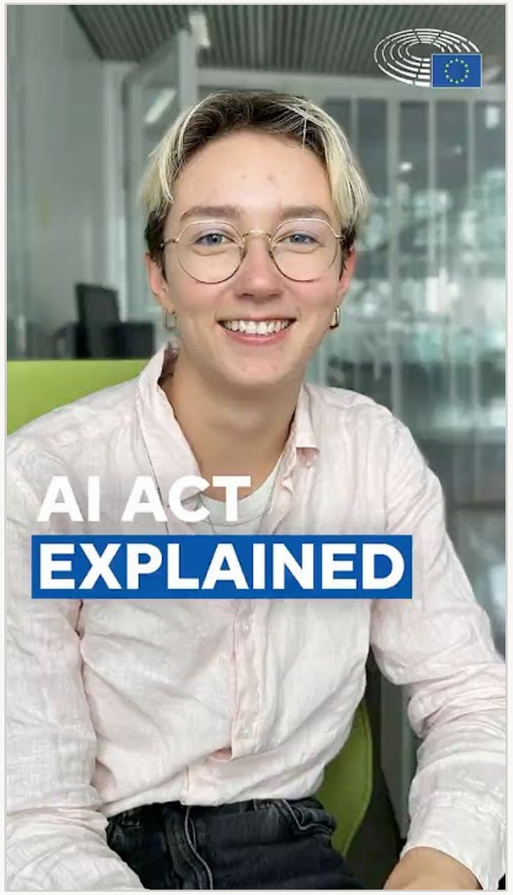
Article 53 attaches information duties to the model provider before downstream integration.



Model ≠ system. GPAI duties can coexist with, rather than replace, system-use duties.

Source: AI Act Article 53 • consolidated text 27 Jul 2026

Institutional communication and regulatory scope



European Parliament • archived public explainer

Source video: EU's AI rules explained • institutional communication, not current legal text

Public risk architecture

The explainer usefully signals prohibited practices, high-risk uses and transparency.

Legal interpretation for the current text

Biometrics: Article 5 uses specific conditions, exceptions and safeguards; it is not a blanket ban.

Generative AI: model supply-chain duties and a deployed system's use duties can both apply.

Native lecturer schematic: communication simplifies; the consolidated Regulation controls the legal analysis.

Sources: European Parliament video • consolidated AI Act • frame 23 Oct 2026

AI Act application is staged

Entry into force: 1 Aug 2024. Several duties already apply under the current consolidated Regulation.

2 Feb 2025
Definitions, AI literacy, most prohibitions

2 Aug 2025
GPAI obligations and governance

27 Jul 2026
Regulation (EU) 2026/1744 in force

2 Aug 2026
Most remaining rules, including Article 50

2 Dec 2027
Article 6(2) / Annex III high - risk duties

2 Aug 2028
Article 6(1) / Annex I product high - risk duties

Current legal frame: enacted Regulation (EU) 2026/1744 and consolidated AI Act dated 27 Jul 2026.

Source: EU AI Act implementation timeline • enacted status 23 Oct 2026

Italy: ChatGPT and the privacy -law overlay

Italy's intervention ran through GDPR enforcement, not an AI Act ban.

Mar 2023

Italy temporarily limited processing

GDPR: basis, notice, accuracy, age assurance

Apr 2023

Access resumed 28 April under conditions

Inquiry ongoing

Dec 2024

Authority Decision No. 755 announced

Purported €15m plus a campaign

Mar 2026

Appeal upheld 2024 decision

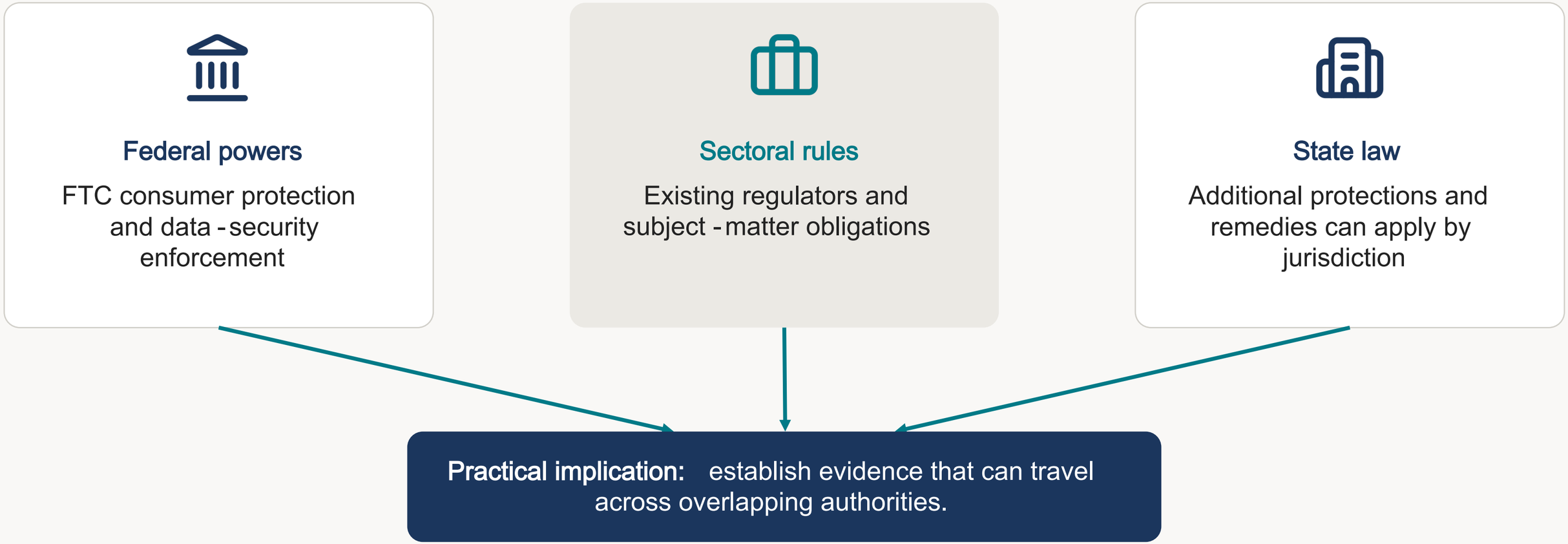
Case page temporarily removed

Restored access did not clear the merits; the €15m was not a final payable fine.

Source: Garante current case status • GDPR case frame 23 Oct 2026

US governance through existing legal powers

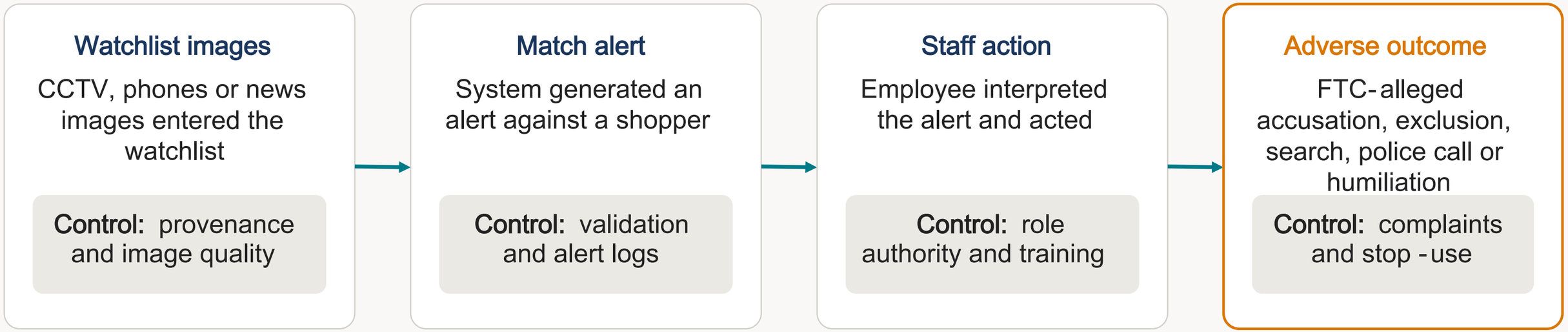
US AI governance is an overlapping enforcement landscape, not a universal AI Act.



Source: FTC Rite Aid announcement • enforcement example, not a universal AI Act

Rite Aid: from match alerts to consumer harm

FTC alleged this 2012–2020 retail facial-recognition pathway; the causal chain is a lecture schematic.



Control lesson: image quality, human authority and complaints monitoring are linked controls; they are not isolated technical checks.

Source: FTC complaint • allegations, not trial findings

Rite Aid remedies change the operating model

The 2024 final order converts controls into prohibitions, records, confirmations and executive accountability.

Stop covered use

Five-year company ban on covered facial recognition or analysis use from the effective date

Delete and attest

Delete pre-effective photos, videos and derivatives, models and algorithms.

Sworn confirmation within 45 days.

Third-party deletion instructions and confirmations within 60 days.

Operate under continuing controls

Notice and complaints process

Risk monitoring and security programme

Independent assessments and annual CEO certification

Scope qualifier: these are order terms, not verified completion or compensation; no monetary payment or redress fund is identified.

Source: FTC modified Decision and Order • issued 5 Mar 2024

Break

Mainland China: the public -service boundary

PUBLIC GENERATIVE SERVICE

Text, image, audio and video services offered to the mainland public

Includes service access through an API

Article 2 scope: the Interim Measures apply to this public -facing service boundary.

NON-PUBLIC USE

Internal enterprise, research and education use not offered to the public falls outside this instrument.

Not law -free: data, intellectual -property, personal -information and sector rules can still apply.

ARTICLE 17

Conditional filing pathway. Security assessment and algorithm filing attach to services with public -opinion or social -mobilisation capacity; they are not a universal filing rule for every model or feature.

Source: CAC Interim Measures, Arts. 2 and 17 · effective 15 Aug 2023

Synthetic-content labels span the media pipeline

1 · PROVIDER

Explicit marker
User-visible text, sound or graphic in content or interface

Implicit marker
Technical and file metadata

2 · EXPORT

Preserve visible markers and technical metadata when generated content leaves the provider environment.

Transfer is part of the label chain.

3 · PLATFORM

Disseminators have their own duties when receiving and distributing synthetic content.

Obligations differ by actor; labels are not a provider-only artifact.

ENGINEERING EVIDENCE Metadata-stripping test across generation, export, transmission and re-ingest

Source: CAC Measures for the Labelling of AI-Generated Synthetic Content · effective 1 Sep 2025

DeepSeek: filing is an administrative status

Official CAC list field	Transcribed English entry
List reference	CAC August 2024 list, row 152
Service	DeepSeek Chat
Filing entity	Beijing DeepSeek Artificial Intelligence Basic Technology Research Co., Ltd.
Number / filing date	Beijing-DeepseekChat-202404280016 · 13 May 2024

CAC Aug 2024 list, row 152; transcribed excerpt

ENTRY: ESTABLISHES

An administrative filing - list status for the named service.

ENTRY: DOES NOT ESTABLISH

Benchmark performance
Safety certification
Approval of every output or downstream use

Filing status is not a performance certificate.

Source: CAC filing announcement and August 2024 list

Hong Kong: PDPO duties and AI guidance

PDPO CAP. 486

BINDING

Schedule 1 Data Protection Principles remain the legal duties.

Collection, use, retention, openness and access duties apply on their facts.

AI adoption does not displace the statutory layer.

PCPD MODEL AI FRAMEWORK

GUIDANCE

11 June 2024 best-practice framework for organisations procuring, implementing or using AI, including GenAI.

It is not a standalone AI Act or statute.

AGENTIC AI SUPPLEMENT

Additional guidance; it does not replace the PDPO or the 2024 framework.

Sources: PDPO Cap. 486 · PCPD Framework 2024 · 2026 Agentic AI supplement

Worldcoin: necessity, fair collection and retention

8,302

individuals with faces and irises scanned

Individuals, not a scan count

PURPOSE

Humanness
World ID
Token process

COLLECTED DATA

Face and iris scans

RETENTION FINDING

AI verification training
Maximum 10 years found too long

PCPD FINDINGS

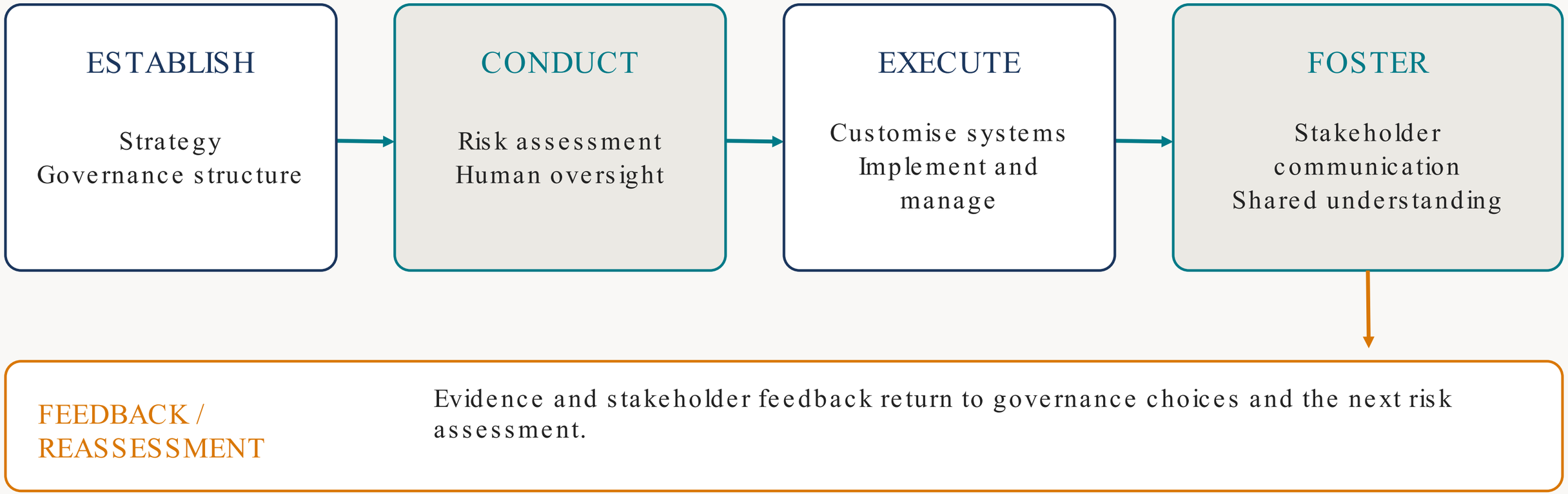
Unnecessary, excessive, unfair use; notice and retention failures under DPPs 1, 2, 5 and 6.

ENFORCEMENT SCOPE

Cease Hong Kong public iris/face scanning and collection. Not a generic AI ban; current operations unverified.

Source: PCPD Worldcoin findings and enforcement notice · 22 May 2024

PCPD's four -step governance approach



Lecturer schematic based on PCPD (2024), Fig. 3; guidance, not a reproduced original figure.

Source: PCPD Model AI Protection Framework (2024), Fig. 3

UK: sector accountability and Ofqual

SECTOR-LED POLICY POSITION

No UK technology -wide high -risk AI Act.

Existing law and sector regulators remain central.

Five nonstatutory principles
Safety, security and robustness
Transparency and explainability
Fairness · accountability · contestability

OFQUAL · SUMMER 2020

Statistical standardisation algorithm, not GenAI

Centre history graded distribution → Group prior - attainment adjustment → Individual rank allocation

Population goals can misfit individual outcomes: a governance problem, not only an accuracy problem.

Sources: Commons Library, 14 Oct 2026 · Ofqual interim report

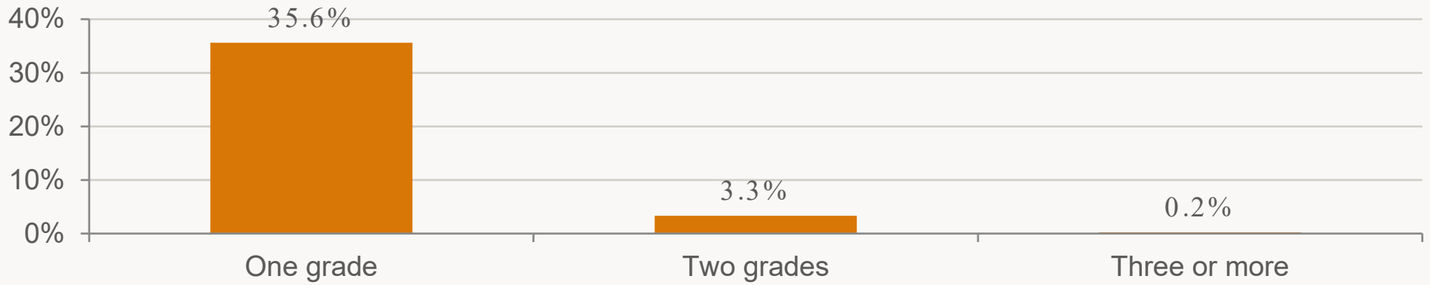
Ofqual: population constraints and individual outcomes

Table 9.8. Percentage of CAGs unadjusted and adjusted [117]

	Total	Adjusted down by			Unadjusted	Adjusted up by		
		3+ grades	2 grades	1 grade		1 grade	2 grades	3+ grades
A level	718,276	0.2	3.3	35.6	58.7	2.2	<0.1	<0.1
AS	70,505	1.1	7.1	28.7	59.8	2.9	0.2	<0.1

Original Ofqual Table 9.8 excerpt. A-level and AS rows retained; chart below uses A-level only.

A-level entries adjusted down, before the 17 Aug reversal

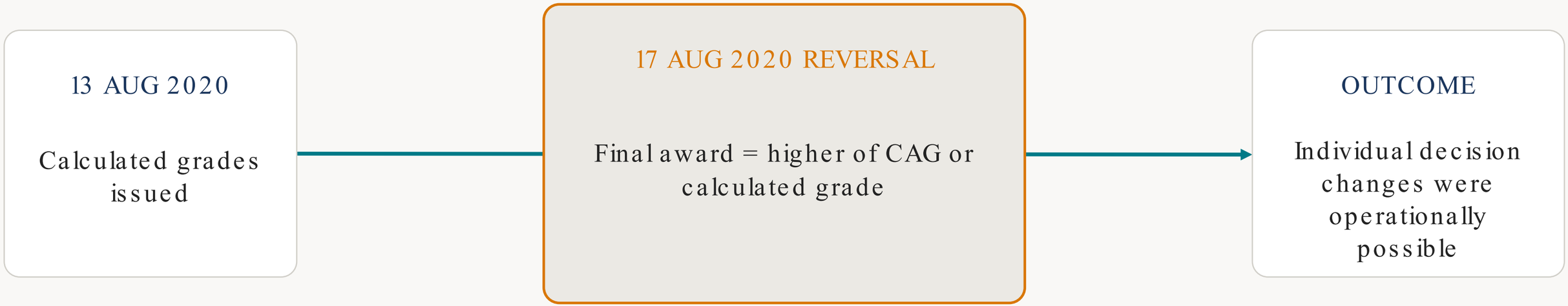


39.1% ADJUSTED DOWN ≥1 GRADE

Rounded bins; denominator: 718,276 matched A-level entries. Not final awards.

Source: Ofqual interim report (2020), Table 9.8 · pre-reversal calculated grades

Contestability requires operational authority



A meaningful appeal has authority to affect the outcome

EXCEPTION AUTHORITY

Correct data, evidence or model-application error.

INDEPENDENT REVIEW

Centre-submitted procedural and data grounds reached review.

ROLLBACK AUTHORITY

Suspend or revise the decision rather than only record a complaint.

Sources: UK government reversal statement · Ofqual appeals guidance

Singapore: voluntary governance and assurance

RESPONSIBILITY ACROSS THE SYSTEM CONTEXT



Original stakeholder diagram · Model AI Governance Framework (2020), viewer p. 18

MODEL AI GOVERNANCE FRAMEWORK

2020 framework: voluntary, living and risk-proportionate.

Human-centric, explainable and transparent, fair.

Not a legal licence, certificate or safe harbour.

LEGAL BASELINE REMAINS

Voluntary governance directs practice. Existing laws, including the PDPA and relevant sector requirements, retain their own force.

Source: Singapore Model AI Governance Framework, 2nd ed. (2020)

AI Verify combines tests with process checks

TECHNICAL TESTS

Fairness
Robustness
Explainability

PROCESS CHECKS

Accountability
Human oversight
Documented controls



Source video · IMDA / PDPC historical MVP film

Historical MVP evidence; the current framework and tool have evolved.

EVIDENCE FLOW

Declared claims → Test configuration → Technical results → Human process check → Bounded report

Testing evidence is not a certificate, legal safe harbour or guarantee of risk-free operation.

Source: AI Verify framework · IMDA launch, 2022

DBS: responsible AI in a banking workflow

Provider-reported 2024 practice · document-assisted ESG risk questionnaire

1 · ESG documents

Uploaded ESG material sets the working context.

→

2 · GenAI draft

Suggested ESG questionnaire responses support review.

→

3 · Sampling

Regular sampling checks the generated work.

→

4 · Human review

Relationship and Credit Risk Managers review.

→

5 · Case decision

Human decision stays in the banking workflow.

Responsible AI oversight

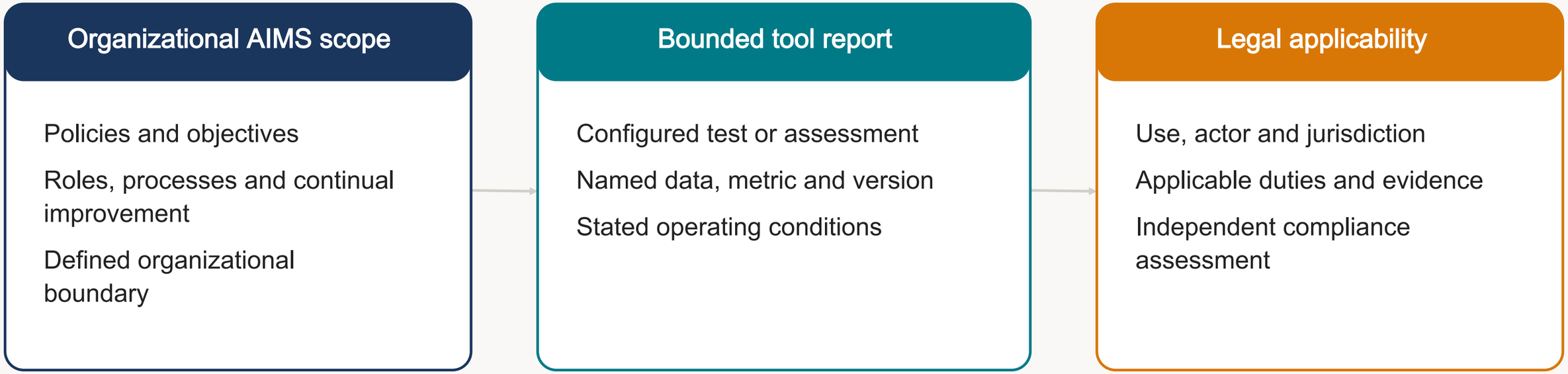
A reported taskforce assessment and cross-functional committee structure frame the workflow. The evidence supports a governance-practice description, not an independent safety result or return-on-investment claim.

PURE principles: **Purposeful** · **Unsurprising** · **Respectful** · **Explainable**

IMDA 2022 pilot: DBS tested and provided feedback; pilot participation was not certification.

A management -system certificate has a scope

ISO/IEC 42001:2023 addresses an organizational AI management system



A certificate scope does not establish **model correctness**, a **universal licence** or **legal compliance**.

Cross-border deployments need layered controls

Reusable engineering baseline · context-specific legal and operational gates

Reusable global baseline

Inventory · purpose record · provenance · access control · testing · logging · incident process

Use and actor gate

Intended function

Provider, deployer and supplier roles

Sector decision authority

Privacy and data gate

Purpose and data basis

Retention and transfer conditions

Individual information and rights

Public-service gate

Public offering boundary

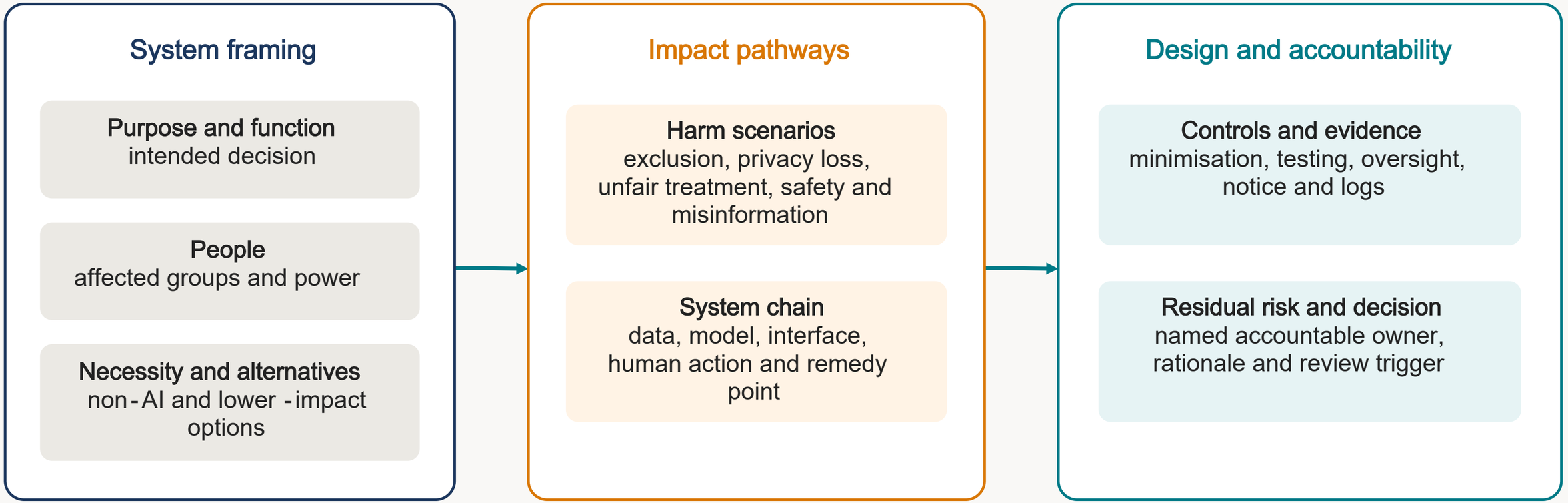
Local notices and content rules

Sector or public-interest conditions

Engineering evidence can travel across borders. Legal obligations remain jurisdiction-and context-specific.

Impact assessment connects rights to design

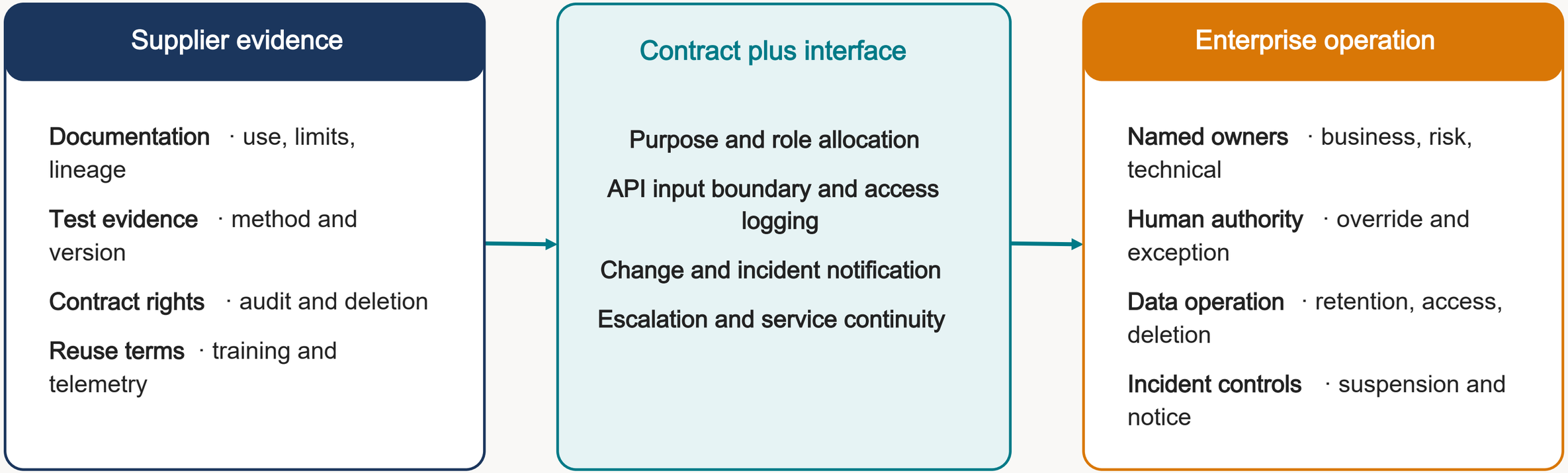
Accuracy is one evidence input inside a wider decision record



Rights become design constraints when the assessment produces controls, evidence and an accountable decision.

Procurement is a governance interface

Business service example · customer-support triage assistant



Procurement converts supplier statements into enforceable operating evidence.

Policy compliance changes after release

A release is a control-state change, not the end of governance



Control ledger

Request ID · affected versions · reason · evidence · accountable decision · incident linkage · rollback path

Monitoring and incident reporting feed the next reassessment cycle.

TalentBridge: a launch -evidence matrix

Hypothetical teaching example · AI hiring SaaS and HR assistant · educational framing, not legal advice

Lens	TalentBridge assumption	EU context	Mainland / HK context	Launch evidence
Use	Candidate ranking support and HR rationale drafting	Annex III employment Use assessment	Public-service boundary; PDPO purpose and duties	Use description; feature inventory; market register
Model	LLM + ranking service Model ≠ system	Article 50 and GPAI duties on their terms	Public labels; data rules where applicable	Model cards; supplier terms; input-output record
Role	Provider; employer deployer; vendor inputs	Role allocation and instructions	Local data-handling duties	RACI; support escalation; owner approvals
Data	CVs, interview notes and recruiter feedback	GDPR applies on its own terms	PI handling; PDPO notices and retention	Data map; minimisation; retention and access tests
Timing	EU hiring workflow launch	Annex III duties: 2 Dec 2027, if applicable	Mainland and Hong Kong gates separately assessed	Dated applicability assessment; decision record
Posture	Hypothetical teaching example	No individual legal conclusion	No individual legal conclusion	Evidence supports an accountable launch decision

The matrix separates system description, jurisdictional context and launch evidence.

Innovation and protection depend on policy design

Conceptual design model · no quantified relationship or causal return-on-investment claim

Policy design choices shape the conditions around invention, deployment and accountability.

Scope and thresholds

Purpose, impact and actor distinctions support proportional treatment.

Administrative pathways

Clear documentation and predictable interfaces reduce avoidable burden.

Assurance infrastructure

Shared methods, testing capacity and evidence formats enable coordination.

Rights and competition

Redress, fair access and market structure remain policy design constraints.

Innovation capacity and protection quality are evaluated through concrete mechanisms, evidence and distributional effects.

Governance is demonstrable responsibility

A decision, its operating controls and its proof travel together



Primary cases and legal sources

Current-source frame: 23 Oct 2026 · concise bibliography for the lecture cases

European Union and United States

EU AI Act · consolidated text

Regulation text · consolidated 27 Jul 2026

Italy Garante · current case status

ChatGPT privacy-law intervention and appeal record

FTC · Rite Aid modified order

Company-specific order terms · United States

Asia and United Kingdom

CAC · Interim Measures and filing lists

Mainland public generative-service boundary

PCPD · Worldcoin findings

Hong Kong enforcement record and PDPO context

Ofqual · interim report

2020 calculated-grade evidence and reversal context

Singapore IMDA · AI Verify pilot

Pilot participation and feedback record

DBS · Sustainability Report 2024

Provider-reported banking governance practice

Primary source links are embedded in each citation label.

Frameworks, media and further reading

Source set for continued policy, engineering and governance study

Frameworks

OECD AI Principles · updated 2024

UNESCO Recommendation · 2021

NIST AI RMF 1.0 · voluntary guidance

ISO/IEC 42001:2023 · AIMS standard

Reviewed source media

European Parliament
EU's AI rules explained · archived public explainer

IMDA A.I. Verify
Historical pilot film · framework and toolkit context

Optional syllabus reading

Dignum, V. (2019)
Responsible Artificial Intelligence

Coeckelbergh, M. (2020)
AI Ethics

Responsible AI becomes credible when systems, evidence and remedies travel together.